

←

 r/Bitcoin • 1d ago

Impressive-Gene-421

...

Are you kidding me? Claude Code found the catastrophe after being asked only to “check for vulnerabilities and thinking for 8 minutes

```
1. ngu.random is wired to a software PRNG, not the hardware TRNG – CRITICAL

There are two independent RNG paths in the firmware, and only one of them reaches the STM32 TRNG.

Path A (correct). ckcc.rng_bytes() → stm32/COLDCARD_MK4/rng.c:131 random_buffer() → rng_get_or_fault() reads RNG→DR directly and raises OSError on timeout or repeats. This is what backups.py:337 uses for the backup-file password.

Path B (broken). ngu.random.* → external/libngu/ngu/random.c:73 CHIP_TRNG_32(), defined at line 24-26 as extern uint32_t rng_get(void).
```

It is unbelievable that some kid with an LLM just stole \$100m+ because no one bothered to check the source code.

Also on GLM 5.2 (trained 16th June, no internet access).

↑ 1.7K ↓

💬 510

🔗 2

🔄

Sort by: Best ▾

🔍 Search Comments

-  JuniorAd1610 • 23h ago
- This is basic CS stuff ffs,literally who is their dev team?
- ⊖ ↑ 488 ↓ 💬 Reply ...
-  mew900 • 23h ago
- Somewhere was info that the one who committed that change was the co-founder / CTO
- ⊖ ↑ 186 ↓ 💬 Reply ...
-  corporate-citizen • 20h ago
- That would be Peter Gray, aka doc-hex.
- The person most clearly associated with the vulnerable Coldcard RNG integration is Peter D. Gray, via the doc-hex account.

r/Bitcoin

Joined

Bitcoin - The Currency of the Internet

Bitcoin is the currency of the Internet: a distributed, worldwide, decentralized digital money. Unlike traditional currencies such a...

Show more

📅 Created Sep 9, 2010

🌐 Public

408K Weekly visitors

8.4K Weekly contributions

COMMUNITY BOOKMARKS

Resources ▾

Podcasts ▾

Other Bitcoin Sites ▾

- RESOURCES
- [Don't invest recklessly](#)
 - [Getting Started](#)
 - [FAQ / Wiki](#)
 - [Resources](#)
 - [Common Myths](#)
 - [How to buy bitcoins worldwide](#)
 - [Bitcoin as a medium of exchange](#)
 - [Will I earn money by mining bitcoin?](#)
 - [Bitcoin as an investment](#)
 - [Storing Bitcoins](#)
 - [Well-Kept Gardens Die By Pacifism](#)
 - [A Cypherpunk's Manifesto](#)
 - [Bitcoin IRC chat](#)

- GUIDELINES
- Do not use URL shortening services: always submit the real link.
 - Begging/asking for bitcoins is absolutely not allowed, no matter how badly you need the bitcoins. Only requests for donations to large, recognized charities are allowed, and only if there is good

defective libNGU feature check.

2. doc-hex **, March 1, 2021:** imported that code, disabled MicroPython’s hardware RNG in the board configuration, and switched master-seed generation to the affected `ngu.random` path.
3. Coinkite, March 17, 2021: released it as firmware 4.0.0.
4. doc-hex **, March 11, 2022:** added a reseed API accepting only a 32-bit integer.
5. doc-hex **, March 11, 2022:** truncated secure-element-derived hash material to 32 bits and used that API for Mk4.
6. Coinkite, March 14, 2022: released the construction in Mk4 firmware 5.0.0.

That is considerably more specific than merely saying “an integration error occurred.”



electromage • 20h ago

If anyone's wondering where their coins went



corporate-citizen • 20h ago

Not suggesting it was malicious or intentional, nonetheless I would seriously consider hiring a security detail if I were in this position.



freedomcoinz • 16h ago

Mark Karpeles, Sam Bankman-Fried vibes coming back with this



1 more reply



gtwooh • 16h ago

Who approved the PR is the real question. Well assuming there is such process on a small dev team



1 more reply



9 more replies



16 more replies

- News articles that do not contain the word "Bitcoin" are usually off-topic. This subreddit is not about general financial news.
- Submissions that are mostly about some other cryptocurrency belong elsewhere. This subreddit is exclusive to Bitcoin.
- Promotion of client software which attempts to alter the Bitcoin protocol without overwhelming consensus is not permitted.
- No referral links in submissions.
- No compilations of free Bitcoin sites.
- Trades should usually not be advertised here. For example, submissions like "Buying 0.2 BTC" or "Selling my computer for bitcoins" do not belong here. [/r/Bitcoin](#) is primarily for news and discussion.
- Please avoid repetition — [/r/bitcoin](#) is a subreddit devoted to new information and discussion about Bitcoin and its ecosystem. New merchants are welcome to announce their services for Bitcoin, but after those have been announced they are no longer news and should not be re-posted. Aside from new merchant announcements, those interested in advertising to our audience should consider Reddit For Business advertising system.
- Do not post your Bitcoin address unless someone explicitly asks you to.
- Be aware that X, YouTube, Facebook, Instagram, etc. are full of impersonation.

R/BITCOIN RULES

- 1 No malicious content
- 2 No trolling
- 3 Do not promote altcoins
- 4 The primary topic is Bitcoin
- 5 Avoid repetition

this makes perfect sense to me. The world is running on bullshit (and it mostly works, by the way). I had a buddy belittled for trying to fix bugs. Gotta move fast and develop more features! I had a buddy replaced by AI to do reverse-engineering. He is an insane stickler for the details and was a huge asset as the rest of the company does not know how to get into the weeds like him.

The unfortunate reality is that this attitude might be profitable. Don't take one catastrophe as proof that it doesn't work. Think about all the shitty products that are out there that are making bank or get acquired.



razvanciuy • 16h ago

Can confirm. Most of the world runs on bullshit, fake it like you made it.



bartiz • 5h ago

Exactly that. The general trend I see in pretty much everything in past decade or two is lie as much as possible, sell, go away.

There's no quality being delivered by companies anymore. There's only chase for profit.

What has happened with world? It's like we're heading into collapse, but nobody gives a F.

5 more replies



ContemptMarzipan • 21h ago

Peter D. Gray made the commit to the code - <https://x.com/grok/status/2083899371330916755>
<https://www.linkedin.com/in/doc-hex-04063811/>



bittabet • 16h ago

The fact that he describes himself as a "wizard level developer" on his own linkedin tells you everything you need to know about this clown. Sloppy and reckless and full of himself.

They didn't even bother to audit their own code with the numerous LLMs that could have found this in minutes. Literally every modern LLM can detect the sheer idiocy.

- 8No faucets
- 9No URL shorteners or referrals
- 10Do not promote contentious hard forks

DOWNLOAD BITCOIN CORE

Bitcoin Core is the [backbone of the Bitcoin network](#). Almost all Bitcoin wallets rely on Bitcoin Core in one way or another. If you have a fairly powerful computer that is almost always online, you can help the network by running Bitcoin Core. You can also use Bitcoin Core as a very secure Bitcoin wallet.

- Latest stable version: [31.1 \(July 2026\)](#) [BitTorrent]
- [Release Announcement](#)
- You *MUST* [verify the integrity of this software](#) before running it.

PROJECTS



CONTACT

message the moderators

FRIENDS OF R/BITCOIN

r/BitcoinBeginners
1,224,340 members

r/BitcoinMarkets

bitcoin disappear! Abracadabra!

+ 1 more reply



29da65cff1fa • 15h ago

someone post this to [r/linkedinlunatics](#)

lol... wizard level... made a taxi hailing app...



goatanuss • 16h ago

Wizard as in now you see it now you dont

+ 3 more replies

+ 1 more reply

+ 9 more replies



shedgehog-orchard • 23h ago

I think what people are missing is that OP isn't complimenting Claude... it's commentary on how fucking stupid ColdCard is and how they clearly did not test their RNG device sufficiently. This entire story is a nothing burger if you used your own RNG methods to generate seed phrases.



HollaWho • 22h ago

I work in IT and vulnerability remediation is part of my role. The last three months have seen record amounts of CVEs month after month. AI is giving so many threat actors tools to quickly identify vulnerabilities. We're getting hammered



cyclism- • 22h ago

Exactly, patching overload right now!

+ 1 more reply



shedgehog-orchard • 21h ago

I do just want to highlight the fact that yes it could be that AI is just finding a lot of bugs we couldn't before, but I also am a full time SW engineer and I'm more and more seeing the shittiest software I've ever seen be shipped because it's vibe coded and the engineer who generated it barely checks it



14,170 members



r/BitcoinMining
86,266 members



r/TheLightningNetwork
10,488 members



r/BitcoinMining
139,484 members



r/CryptoAnarchy
9,013 members

MODERATORS

Message Mods



u/theymos



u/BashCo



u/frankenmint



u/rbitcoin-bot



u/Aussiehash



u/ThePiachu



u/Avatar-X
Avatar X



u/rBitcoinMod



u/logical



u/pb1x

View all moderators



Aazimoxx • 21h ago

You don't get CVEs for software no-one's using though, and a lot of vibecoded slop is either dead in the water (app store noise) or bespoke stuff used by an individual, family, group or club, or single company mostly internally...

If a company has decent review procedures, these can only be enhanced by modern LLMs, not hurt - unless those procedures get bypassed, which is the real problem.

+ 1 more reply



HollaWho • 21h ago

That's absolutely part of it. AI is a double edged sword as far as vulnerabilities go. And many of the latest Microsoft vulnerabilities are coming from Microsoft's mishandling of the nightmare eclipse situation. Times are tough lol

+ 2 more replies

+ 3 more replies



haggardphunk • 20h ago

I work in appsec and it's literally a game of AI vs AI over here. Our corporate leadership is taking it very seriously and we're tightening up remediation timelines so much that even I wonder how anyone could fix this shit in time without AI.



HollaWho • 20h ago

Every kid and their babushka in Russia has AI. The flood gates have opened, and you literally have to use it to keep up.

+ 3 more replies



ColoradoStudent • 18h ago

Same, man. We've never been busy like this before. WordPress is getting wrecked.

JustSkillfull • 18h ago

core platform who owns 100's of different services from 3rd parties + some custom in-house projects has turned from software engineering delivering features to the robot from Rick and Morty who's sole purpose is to pass the butter but patch the images.

Recently (12 or so months) it's moved from 20% KTLO (patching / fixes) to 70% KTLO. We've moved to more secure base images from a 3rd party hardened paid image repository, and constantly behind SLOs since we were a Federated US Gov programme we have very strict SLO handling and exception processing.

Some weeks it's just patching. 60 images all need patching, tested, and deployed. Fun.



jungle • 17h ago

Ah yes, fedramp must be a nightmare right now.



JustSkillfull • 16h ago

Luckily they're moving away from CVE 🙌 just waiting for the Auditors and Internal Security team to gang up on that new requirement



TheWaffleKingg • 20h ago

Id be drinking too if i had to deal with all that

Jokes aside, im glad im not working on the security side of things nowadays. I can only imagine how busy yall have been. But hey job security?



HollaWho • 20h ago

I'm spending too much time explaining to a management why we can't be comparing vulnerability count to a few months ago, or this month last year. Then getting hassled by the user base for a new Microsoft Edge mandatory close out on Fridays. We're even using toast notifications telling them to close their shit. Just update it! Sorry, I'm spiraling lol



Defenders have the same tools to find and patch them first. Security by obscurity was never a thing. NSA and the PLA likely already knew about most of them.



ignnies_doit_4_free • 19h ago

the people blaming Bitcoin and having messy diapers about "the future of bitcoin" when coldcard's fuckup was this monumentally retarded is really silly



Forsaken-Stink • 17h ago

Its opensource anyone can verify!



Any-Box-8663 • 14h ago

Yes, that person verified, then took all the coins for themselves and got the reward....



4 more replies



habbadee • 22h ago

Let's imagine Coldcard learned this bug was out there in the wild. What do they do about it?

Obviously they issue a firmware patch, but how do they get people to apply it and generate new seeds without alerting the world of the flaw and the fact that bad actors can determine seeds?

They can't notify owners of the devices. They can't announce the reason for the firmware fix when telling people to apply it and generate new seeds. Once the bug was out there and vulnerable seeds generated, they were well and truly screwed because fixing it would announce it's existence.



FastRelief3222 • 20h ago

https://www.reddit.com/r/coldcard/comments/17fy8cz/17_btc_drained_instantly_using_sparrow_to_cold/

https://www.reddit.com/r/Electrum/comments/id7bpj/the_loss_of_bitcoin/

https://www.reddit.com/r/coldcard/comments/17epqk8/40_bitcoin_taken_instantly_from_my_coldcard/



+ 1 more reply

**Kine7ic** • 21h ago

Great point. I haven't seen anyone bring that issue up before. I assume they would put out a generic warning about certain firmware versions and send that to their email list. But then users would still need to move to a new address made by the new firmware to be protected. Hardware wallets need to be perfect from release with critical systems like their seed generating code. Once you find a flaw this deep it would be a disaster for a company to tell everyone to make a new wallet address.

**No-Contribution23** • 18h ago

true, it would be a disaster, but still better than what actually happened.

**lInsulince** • 15h ago

This is exactly why I believe it's more likely that they did know about this bug, and for how much I loathe them for putting the people who did the best they possibly could for their stack, I do have trouble blaming their "inaction". Their hands are tied in a cruel joke that the very act of trying to fix it makes the problem immediately worse.

Action is damaging in this case because attackers move far faster than customers. As soon as any kind of announcement is made, the attacks are in full swing. Therefore, it may be "best" to just stay quiet. I mean... man I mean I don't know what's best in this scenario. There's no way to move anyone without revealing the problem to everyone. The best I can think of for taking actual action would be to release a vague but loud statement that a critical bug has been found and it's paramount that keys are rotated and funds moved, but without stating why or what the cause was. This would alert attackers that "something" is wrong, but not specifically what... still I think attackers would act quickly and find it before the majority of customers can escape to secure keys.

I just think that when faced with the idea that the security-fist and leading hardware wallet company never once, over 5 years, tested the execution path of their device to actually generate truly random numbers, arguably the only job of the entire device, I have trouble accepting that. It's a level of incompetence so ridiculous that it makes me think conspiracy is more likely. But



10x worse immediately.

Idk, I guess it's more likely they're actually just that incompetent, but holy hell that's such a massive L. Fuck CoinKite.



EconomyDoctor3287 • 13h ago

Doing nothing just means an attacker has time to prepare a plan before acting on it



1 more reply



carsonthecarsinogen • 17h ago

I think the standup thing to do would be to publicly announce they are shutting down operations and wont be continuing to update their products while telling customers to migrate to a new company.

This would kill their business overnight but at least people wouldn't assume there's a vulnerability and the majority would transfer.

Idk, it's a tough one.



lInsulince • 15h ago

People would migrate without changing their seed. They'd simply import it. That's not sufficient.



Mallmagician • 20h ago

Maybe their only option is to drain those wallets themselves using the vulnerability. Then return them to the original owners once the funds are secured and the original owners have secure wallets again.



Rannasha • 19h ago

How do you identify the original owners? The standard method of proving address ownership (signing a message with the private key of the address) isn't usable since an attacker can crack the seed using the vulnerability and provide proof of address ownership.



3 more replies



1 more reply



dondondorito • 23h ago

Yeah, this is what I expected. The fact that a massive critical bug was exploited shortly after the release of Fable was highly suspicious.

This sort of thing will happen more often now. It is extremely unsettling that the developers didn't test their code with Fable, after Anthropic released it.



magicmulder • 23h ago

I would bet an older model would have found this as well. At least since 4.6 Opus, Claude has been very good at discovering such flaws as "if this condition applies, the code silently falls back to a less secure approach". I get this all the time when auditing code with those models.

This case is not some crazy godlike "no human would ever have found this" (like when that guy hacked the PS3 by manipulating the USB port in weird ways), it's a pretty glaring oversight in both code and testing.



shedgehog-orchard • 23h ago

I was just gonna say. All this talk about AI, they did not need AI to detect this error 🧑 for all we know the hacker could have discovered this themselves without AI it's such a massively stupid fuckup on the ColdCard



wentwj • 21h ago

it's immensely surprising to me this wasn't caught without AI and wasn't exploited years ago. This is basically the textbook thing you'd look for in "is this hardware wallet secure". You'd look at how it does its key gen and if it's doing something stupid there, not using true random being one of the main things it could do wrong there



shedgehog-orchard • 21h ago

Completely agreed! I have no evidence to suggest this but just trying to think like the hacker, they could have even discovered this years ago but waited for the ColdCard to gain traction and/or see if anyone would discover it first. Probably unlikely given the patience



+ 2 more replies

+ 1 more reply



Crypto-Guide • 22h ago

I actually had a few models review the coldcard codebase over the last year and none of them found this issue.

I have been testing a few things and basically most LLMs will find it if you give them a specific prompt to look for this specific type of bug, but it's only the frontier models (like Kimi k3) that will find it on their own.

-



EdmundTheInsulter • 21h ago

when stuff goes wrong in IT, people always go off and look for whatever tool would have prevented it, but no one could ever have used and applied every tool correctly. On top of that there are truly stupid people around, you only need one totally weak link.

I experienced endless cases where people couldn't back up and secure databases, for example thinking that disk redundancy was a 'backup', which it wasn't if the whole machine was destroyed, but what actually happened is that the redundant disks failed without them knowing until too many failed - total incompetency, but the people just stayed at the company etc.

Issue 2 was a guy who had a website, he was backing up his large database onto his copy, but while he was backing it up, his database failed whilst overwriting his only copy - he was actually that stupid and too stingy to have equipment to backup his backup, or even foresee that total failure scenario (all avoidable in 1001 ways), like the first one, they couldn't foresee the machine in one room could catch fire

+ 1 more reply

+ 3 more replies



nullc • 16h ago • Edited 16h ago

🏆 Top 1% Commenter



They disable the built-in TRNG wrapper to replace it with their own version that was more sensitive to unexpected behavior (maybe too sensitive, but that is another issue...), but the code that triggered their replacement was done in an inconsistent way that caused it to not actually get enabled.

This is because the micropython code disables the TRNG when `MICROPY_HW_ENABLE_RNG` is 0 but the replacement code tests for `MICROPY_HW_ENABLE_RNG` being defined at all, and if it is set to zero it is still defined. If both modules checked the value or if both modules checked for definedness then the behavior would have been correct (or would have failed to compile). Because of the inconsistency the TRNG was replaced by an insecure PRNG that still behaved in a way that appeared and would test as correct.

So it's like disconnecting the shoe breaks on your bike to replace them with disc breaks but the ferrule on the disk break cable is differently shaped and doesn't actually engage with the handle when connected, leaving you with no breaks. But from a quick glance it looks like one set of breaks were disconnected and another set connected.

+ 5 more replies



Archophob • 22h ago

you don't need Fable. Any LLM with coding abilities can find this. "Security by obscurity" is gone for good.

+ 6 more replies



numbersev • 22h ago

Mythos found a bug used throughout the internet that had existed since 1998 and no security research team or individual ever spotted it. It was so significant that they had to stop the release, give it to 50 of the biggest American companies to patch their systems and then re-released it later.

+ 4 more replies



nullc • 16h ago

📬 Top 1% Commenter

No fable is needed for this, Qwen 3.6-27b finds it too.



+ 4 more replies

**thambassador** • 23h ago

Can someone do this on Trezor code and see what Claude says?

**Major-Front** • 21h ago

If they did and found something do you think you'd still have your bitcoin lol

**FigAggressive237** • 20h ago

Yes he could have, why are you assuming that?

This hack in particular lowers the seedphrase's entropy from 2^{128} , to 2^{40} and 2^{72} depending on the firmware, but this is an upper bound I believe

If its remotely close to 2^{72} , its still safe-ish. I do think that each guess requires PBKDF2-HMAC-SHA512 (2048 rounds) plus elliptic-curve point derivation to check if it produces the target address.

Check how much power you need to derive such seedphrase.

+ 2 more replies

+ 5 more replies

**Impressive-Gene-421** OP • 1d ago

Fuck me okay I will run this on GLM from 16th June lol will that prove it?

**username12435687** • 1d ago

Dude don't even stress on it. Anyone with half a brain and a basic understanding of programming realizes you're 100% correct in this post. The people disagreeing are just technologically illiterate which is insane considering they're on a Bitcoin subreddit lmao

**quantum_burp** • 21h ago

Most of the people in here now are normies



theetacker • 23h ago

Even a chimp could have realised that.



15 more replies



GentlemenHODL • 23h ago

Fuck me okay I will run this on GLM from 16th June lol will that prove it?

Yes.

Do it and get back to us. That's the only way to conclusively prove!

Good luck



jan386 • 22h ago

They just did:

https://www.reddit.com/r/Bitcoin/comments/1vdes1l/update_to_my_last_post_glm52_trained_june_16th_no



GentlemenHODL • 22h ago

Awesome thank you.



9 more replies



Henrik-Powers • 23h ago

Can you also do the same with ledger and trezor and see if it comes up with anything? 🤔



dempsey1200 • 22h ago

They have to be scrambling right now. Lucky that it happened to a small provider before the big ones get hit. They should be in Project Glasswing, IMO.



PM_ME_A_STEAM_GIFT • 22h ago

How would they even react if they found something similar? They can't announce it or they would expose every wallet to hackers. Silently patching the firmware also doesn't fix affected wallets.



I think they would have to sweep everyone themselves and return it white hat style. no other way.



Mission_Shopping_847 • 18h ago

Every crypto interested hacker is now sniffing the ecosystem harder because of this coldcard hack.

+ 2 more replies



jannies_doit_4_free • 17h ago

before

what do you mean "before"? this bug is absolute amateur-hour ridiculousness that only happened seemingly because it was such an amateur operation

+ 1 more reply



Cyromaniap • 22h ago

Not sure about Ledger devices but Trezor devices use multiple sources when generating the seedphrase so even if one of the chips has a flaw the seedphrase is still not compromised.

Source: <https://trezor.io/guides/trezor-devices/trezor-fundamentals/what-is-entropy-and-how-does-trezor-generate-your-wallet>



na3than • 21h ago

📬 Top 1% Commenter

If you're trusting a vendor's statement about how their product works you've completely missed the point of the ColdCard incident. Coldcard mk4 and Q were also supposed use multiple sources of entropy when generating the seedphrase. The problem isn't that ColdCards was insecure by design; the problem is that a change introduced long after the secure system was designed and implemented inadvertently bypassed one of those sources and their test protocol wasn't sophisticated enough to detect it.

Coinkite would have said the same thing prior to the attack. Coinkite *believed* their firmware



+ 1 more reply



Indyxc • 14h ago

Hate to say it,, I love BTC, and used to store all of it on cold storage (ledger), but decided to move it to Fidelity when Ledger started scheming with back up recovery options. Not my keys, not my coin sure, but if Fidelity goes under, with 18T AUM, the only thing worth money will be fuel, bullets, guns, and food.

+ 1 more reply



PeterZ4QQBatman • 1d ago

This morning I tried to reproduce the Coldcard RNG bug discovery process.

I checked out the repository at commit 37e4af5 (May 2021) and gave the code to some AI models for a security review.

Composer 2.5, Grok 4.5 High and GPT-5.6 Luna High.
None of them found the bug even after telling them to check the code that generate a new wallet. Nothing.

Note. I had to explicitly tell them not to search the internet, because Grok 4.5 found the bug after checking GitHub.

I will try 5.6 Sol and Opus 5 too.

+ 1 more reply



-5H4Z4M- • 23h ago • Edited 17h ago

Irony is that you hear everywhere that "This shit is 100% secure because it's 100% open source", but "open source" just means the code is available to be checked by anyone....and it wasn't.

edit : Guys before jumping on me saying it was source visible only (which i know) , please read again the part where i intentionally put quotation marks to describe what WE HEAR EVERYWHERE. This are not my words but what you mostly see on forums even from IT people. My post was actually the point of showing that people mix everything together.

+ 2 more replies



fanfanye • 1d ago



humans , then add it to their knowledge database

do the same thing 2 weeks ago and it will find nothing



Cryptizard • 1d ago

You can disable its ability to search the web and just have it work on a local repository. It can still find the error (just tested it).

+ 4 more replies



Late-Football9106 • 1d ago

imagine coding something that handles real money and using a software RNG like nobody would notice, absolute madness

the amount of trust people put in random github repos is wild, one bored dev on a tuesday can just push an update and suddenly your hardware wallet is a paperweight

this whole thing reads like a postmortem that will be studied in security courses for next decade



Fuflen • 23h ago

Just my thought!



aleqqqs • 1d ago

imagine coding something that handles real money and using a software RNG like nobody would notice, absolute madness

Well, they didn't do that on purpose ...



SpareEconomy1849 • 23h ago

A coinkite dev literally changed `MICROPY_HW_ENABLE_RNG` to 0 in the firmware codebase with the commit message "runs" in 2021.

I don't see how it could be intentional, but I also don't know how this would be missed. How did the developer not realize what this change does? How did this pass code review? Red flags all around



To me it DOES appear intentional but not malicious. It sounds like whomever did the coding did not understand what was going on and set the variable to 0 to get it to compile. Once it did they were like 'Kew! It runs. Ship it!'.

 $\oplus$

+



I don't know what to say about that chief. I am working at a cybersecurity company developing very custom auth solutions, sandboxed infra and a lot of other kinds of security critical software, and we use both Claude and Codex to do preliminary security reviews to our changes before any human reviews and I lost count how many times the models raised legit and not obvious issues

+



No, you can literally fork the repo locally, deny any web search permissions and tell claude to audit it, and he will probably find it. That's how good they are these days

+



Your understanding of what llms are capable of is years out of date

+



Just like the math proofs that were found over the last weeks, that no person has found until now and thus couldn't have talked about online?

This is a community about a technology that has revolutionized assets and financials in many ways.



Can't make this shit up... The circle of life...

+ 1 more reply



bbibber • 23h ago

If you think that's the level of AI you are still living in 2023.



zazzologrendsyiyve • 23h ago

You are really uneducated about how AI works



harvested • 23h ago

👤 Top 1% Commenter

You should delete this post, you utter clown.

The bug was found by the attacker with AI which disproves your point.

I don't know who is up voting you.

+ 11 more replies

+ 34 more replies



Aggravating_Stage996 • 1d ago • Edited 1d ago

As an electrical engineer working in a firmware/software role. I would guess this hardware wallet was made by a computer science engineer.

"Oh this is easy! *Does 0 research.* Grabs a popular chip and installs some libraries off git. Call this function and call that function and bam. There it is, the final product and it only took me a few days to make!"

What do you mean TRNG? What's that? I don't need it! See it works fine! Entropy? What's that? I called Random(), so the result must be!

-



Impressive-Gene-421 [OP](#) • 1d ago

Even worse haha, it was "call this function and call that function and huh, it doesn't compile, I'll just set this to 0, now it compiles bam!" (seriously)

-



Aggravating_Stage996 • 1d ago

enough to demonstrate the isolated capabilities of the chip. It seems even just copying that tool generated code and gluing it to theirs was too much hard work for them!



Express_Living2264 • 22h ago

tbf. that's how a playstation got hacked. the rng function always returned 0 iirc.



magicmulder • 23h ago

Yeah the “testing” that they did was something I'd fire a junior dev for. Proper testing does not just check for some flags, it validates that the expected functions are called, and the functions we absolutely don't want called are not called. Which includes a “fallback to a weaker approach”.



cgimusic • 17h ago

I'm kind of curious why they didn't have it tested by one of those companies that certifies gambling machines. Auditing RNG is basically their entire job.



mlhender • 1d ago

No. Actually the CEO does not have a computer science degree.

When you get a computer science degree you will learn that computers are deterministic. You will learn that even with “AI” you cannot achieve true randomness unless you have a physical entropy source.

Most computer science degrees will spend considerable time discussing randomness. Just off the top of my head randomness (and pseudorandomness) were at least mentioned in Discrete Mathematics, Probability and Statistics, Algorithms, Data Structures, Computer Security, Cryptography, Operating Systems and Distributed Systems.

We spent an entire section in probability and stats of how difficult it is to produce true randomness.

You can't get through a reputable CS degree without having at least a good grasp on how difficult it is to achieve true randomness with a computer



16



Reply



**FreezedPeachNow** • 23h ago

While cold card fucked up big time, it's easy to point a tool at a known problem and tell it to find the problem in hindsight.

Finding the problem before others were aware it's a problem is a different story.

But still fuck, this is gonna set us back years



16



Reply

**Aazimoxx** • 20h ago

it's easy to point a tool at a known problem and tell it to find the problem in hindsight.

Bruh. Prompt was literally "check for vulnerabilities". Let's not break our backs trying to bend over too much for the million dollar+ companies.

This sort of adversarial AI code review (before each release) should be a mandatory checkbox for business liability insurance, like having annual smoke detector checks in a building.



8



Reply



4 more replies

**BTTammer** • 20h ago

Does anyone remember a month or two ago when the feds had a meeting with certain large companies to tell them that AI found some really troubling shit really quickly and they need to make preparations ASAP?

Pepperidge Farm remembers....



3



Reply



1 more reply

**shuozhe** • 1d ago

That's prolly how it was discovered..?



8



Reply

**circumcisingaban** • 23h ago

thats what i was wondering

**Powerful_Quarter691** • 1d ago



time. But I agree with the part that someone with little to none knowledge could have also performed this attack, probably even attempted once the news was out.



asml84 • 1d ago

I'd even argue the original attacker is currently competing with other (secondary) attackers.



spislatta • 21h ago

Given how easy it is to find with AI, I think they probably didn't dare to preplan it too much. Waiting just a week could create a significant risk of someone else stealing the money first.



3 more replies



mybodywatch • 23h ago

How do you get your Claude Code to be so terse. Mine is a verbose mess.



2



Reply



Aazimoxx • 19h ago

Excerpts from my own global instructions, hope they help:

Respond very concisely by default; interaction with the user should comprise short, high-information outputs unless expansion is requested.

Be constructively critical when it improves the work, and **avoid performative agreement or disagreement**. Flag material risks, weak assumptions, and unsound technical choices when they may harm correctness, maintainability, safety, or outcome quality; give **concise** reasoning and a practical better path.

Before adding or expanding instructions, review related existing instructions and **prefer the smallest effective refinement**.

The bits I've bolded here definitely tend to make a meaningful difference to unnecessary verbosity, with the last one helping massively to cut down on instructions bloat.

[Create](#)

No_War_8891 • 20h ago

it is easy if you know where to look - hindsight bias; But yeah
it is a big oversight nonetheless I concur

↑ 2 ↓ [Reply](#) ...



10nmTransistor • 20h ago

Sometimes I wonder, what all other vulnerabilities are out
there in other important open source codes. Gives me
goosebumps.

↑ 2 ↓ [Reply](#) ...



Zealousideal-Bug1837 • 13h ago

It's not that this stuff is difficult. It's that it's basically day 0
and it's becoming automated more and more.

↑ 2 ↓ [Reply](#) ...

[View more comments](#)